

Third-Party Risk and Control Assessment

Apache Fineract as a core banking platform for a UK retail bank

Governance · Risk · Compliance · Audit

Prepared for: Bank A (hypothetical client profile, see section 2.1): Chief Information Security Officer and Head of Third-Party Risk

Prepared by: Berk Ozcan, BSc Computer Science, University of Leeds

Date of issue: 8 September 2026

Subject: Apache Fineract, source tag 1.15.0 (10 July 2026) and container image apache/fineract:latest (digest sha256:e9389051, built 7 September 2026)

Version: 1.2

Evidence repository: github.com/Berk-hub/grc-portfolio/fineract

This report is an independent, unsolicited assessment written as a portfolio piece. Bank A is a hypothetical client used to give the findings a realistic regulatory context. No Bank A exists and no real institution's data was used. All evidence was gathered from public sources: the Fineract GitHub repository, Docker Hub and the OpenSSF Scorecard service.

Board memo

To: CISO and Head of Third-Party Risk, Bank A

From: Berk Ozcan

Date: 8 September 2026

Subject: Apache Fineract for the micro-loan product line: assessment opinion and conditions

Opinion: suitable with conditions. Fineract can be used as the core system for the micro-loan product line, provided the three conditions below are met before go-live. None of the findings is a defect in Fineract's banking logic. All of them concern how the software is packaged and deployed, and all of them are within Bank A's control.

What I looked at. The published source release (1.15.0), the official container image, the sample Kubernetes deployment files in the repository, and the project's governance as measured by OpenSSF Scorecard. I did not run the application or test exploitability.

Three findings that matter

- 1. The official image ships unpatched components (F-01, High).** The image built on 7 September 2026 contains Tomcat 10.1.55 with three critical vulnerabilities, two of them authentication bypasses, plus eight high-severity issues in Netty, HttpCore and the PostgreSQL driver. Fixed versions exist for all eleven.
- 2. There is no release-tagged image (F-02, High).** Docker Hub only publishes images tagged by commit hash, develop and latest; latest is the development branch, currently 630 commits ahead of the 1.15.0 release. The image Bank A would pull can be identified by digest, but it cannot be shown to correspond to a release the project has formally approved.
- 3. Sample deployment files are not production-safe (F-03, F-04, Medium).** The database bootstrap grants the root account full rights from any host, and the containers run with the default security context. The files carry no warning that they are samples.

Conditions of approval

- Bank A builds its own image from the 1.15.0 source tag with Tomcat 10.1.58 and the other fixed versions applied, signs it, pins it by digest, and passes a scan with zero critical or high findings before go-live.
- Bank A writes its own Kubernetes manifests with a dedicated least-privilege database account, non-root containers and a read-only root filesystem; the repository samples are used as reference only.
- Bank A runs static analysis (SAST) on the pinned source tag and closes or formally accepts every high finding before go-live, because the project pipeline does not do this.

Residual risk after conditions (target): Low to Medium. This is a target position: the conditions have not yet been implemented or tested, so verified residual risk has not been assessed. Ongoing obligations: re-scan on every Fineract release and at least quarterly; subscribe to the ASF security announcements list; record Fineract in the third-party register as a material ICT service under PRA SS2/21 and, for the Irish branch, under DORA (subject to the applicability note in section 6).

Decision requested: approve conditional onboarding, assign an owner for each condition, and set a go-live gate that checks all three.

1. Opinion and summary of findings

Question this report answers: can Bank A rely on Apache Fineract as the core banking platform for a new micro-loan product line, and under what conditions?

Opinion: suitable with conditions. Overall risk before conditions: High, driven by F-01 and F-02. Overall target residual risk after the three conditions in the board memo: Low to Medium.

Eight findings were raised: two are rated High, four Medium and two Low. Seven controls were found to be operating as expected and are listed in section 7.9.

ID	Finding	Asset	Rating
F-01	Deployed image ships Tomcat with three critical authentication vulnerabilities and eight high-severity dependencies; fixes exist for all	#2, #5	High
F-02	Official container images carry no release version tag; latest is the development branch	#5	High
F-03	Database bootstrap grants the root account full rights from any host	#1, #2	Medium
F-04	Sample Kubernetes deployments run with default security context and writable root filesystem	#4, #5	Medium
F-05	Deployment manifests have no stated purpose (demo or production)	#5	Low
F-06	CI workflows do not follow least privilege; branch protection is partial	#5	Medium
F-07	No static analysis or fuzzing in the project pipeline	#1, #2	Medium
F-08	Database password passed on the command line in health probes	#3	Low

Assets are numbered as in section 2.3. Ratings follow the criteria in section 3.

2. Scope, methodology and limitations

2.1 Client profile (hypothetical)

Bank A is a UK-incorporated retail bank with about 1.5 million customers, authorised by the PRA and regulated by the FCA. It has a branch in Ireland, so the EU Digital Operational Resilience Act (DORA) is assumed to apply to that part of the business alongside the UK regime (see the applicability note in section 6). Bank A is evaluating Fineract as the core system for a new micro-loan product line and intends to host it on its own Kubernetes platform. This profile was chosen so that the assessment has to answer to both the UK and EU third-party risk rules; it is not a real institution.

2.2 Subject of assessment

Apache Fineract is an open-source core banking platform (Java, Spring Boot) maintained as a top-level project of the Apache Software Foundation. It provides client, loan, savings and accounting functions through a REST API and is used in production by microfinance institutions and fintechs. Two artefacts were assessed:

- Source code at git tag 1.15.0, commit d5636847ac, dated 10 July 2026 (the latest release).

- Container image `apache/fineract:latest`, digest `sha256:e9389051`, built 7 September 2026. No image exists for the 1.15.0 release (see F-02), so the published image had to be assessed as-is.

2.3 Assets in scope

The assessment is organised around five assets. If one of these is compromised the bank suffers direct customer, regulatory or financial harm.

1. **Ledger integrity.** Loan balances, repayments and interest postings must be correct and unalterable after the fact. A corrupted ledger cannot be rebuilt from other sources; it causes direct customer detriment, misstated financial records and a reportable incident to the FCA.
2. **Authorisation and privileged access.** Only the right role should be able to create, approve or reverse a transaction. Fineract's maker-checker model depends on authentication working; if it can be bypassed the four-eyes control is gone and fraud by insiders or outsiders becomes possible.
3. **Customer data confidentiality.** Names, addresses, identity documents and account histories are personal data under UK GDPR. A breach that is likely to result in a risk to individuals' rights and freedoms must be notified to the ICO without undue delay and, where feasible, within 72 hours; it carries potential fines and loss of customer trust.
4. **Availability of the lending service.** Customers must be able to draw down and repay. Under FCA operational resilience rules (SYSC 15A) the micro-loan service is a candidate important business service; formal designation and the setting of an impact tolerance are management responsibilities of Bank A. An outage beyond a set tolerance must be reported.
5. **Software supply-chain integrity.** Bank A must be able to state exactly which code it is running and show it has not been tampered with. Unversioned images and unpatched components make that statement impossible and would fail a PRA third-party review.

2.4 Methodology

Evidence was collected as at 8 September 2026 in a GitHub Codespaces Linux environment. Tool versions: Trivy 0.74.0, Syft 1.51.1, OpenSSF Scorecard v5.5.0 (via `scorecard.dev`). The commands below produced the evidence files listed in Appendix A.

Step	Command	Output
Clone and identify version	<code>git clone https://github.com/apache/fineract; git describe --tags; git checkout 1.15.0</code>	Version and dates
Source scan	<code>trivy fs --scanners vuln,secret,misconfig /tmp/fineract</code>	<code>trivy-1.15.0.txt</code>
Software bill of materials	<code>syft dir:/tmp/fineract -o cyclonedx-json</code>	<code>sbom-1.15.0.json</code>
Image scan	<code>trivy image apache/fineract:latest</code>	<code>trivy-image-latest.txt</code> , <code>trivy-image-crit-high.txt</code>
Image identity	<code>docker image inspect apache/fineract:latest</code>	Digest and build date
Tag check	Docker Hub tag filter for 1.15 and 1.14	<code>dockerhub-no-tag-*.png</code>
Governance	<code>scorecard.dev</code> viewer; <code>git shortlog</code> , <code>git log</code> on release tags	<code>scorecard.png</code> , release dates
Manual review	Reading <code>kubernetes/*.yaml</code> , <code>SECURITY.md</code> , <code>.github/workflows</code>	Findings F-03, F-04, F-05, F-08

2.5 Limitations

- **Static and governance review only.** The application was not run and no dynamic or penetration testing was performed. Exploitability of the reported CVEs in Fineract's configuration was not tested.

- The source-tree scan of 1.15.0 found no dependency vulnerabilities because Gradle dependencies are resolved at build time; the SBOM from the source tree (132 packages) is therefore incomplete. The container image, which contains the resolved JARs, was used for dependency findings instead.
- The image assessed is latest, not a 1.15.0 release image, because no release image exists. Dependency versions in a self-built 1.15.0 image may differ.
- Bank A is hypothetical. Ratings assume a regulated UK retail bank with an internet-facing deployment; a different risk appetite would change some ratings.
- This is a screening-level assessment by a single reviewer, not a full audit.
- DORA applicability to the Irish branch is a stated assumption, not a legal determination. Whether a branch of a UK bank falls within DORA's scope depends on its legal form and authorisation; the mapping in section 6 is conditional on this and would require legal validation in a real engagement.
- Article-level references to the Turkish BDDK regulation in section 6 are given at topic level only and have not been verified against the current text.

3. Rating criteria

Ratings were fixed before the findings were written, so that the same standard applies to every finding.

Rating	Definition	Expected action
High	Affects asset #1, #2 or #5; a public exploit or fix exists, or the condition would fail a regulatory review on its own. Blocks go-live.	Fix before go-live; condition of approval.
Medium	Real weakness that needs a precondition (for example, a sample file used in production) or is mitigated by another control. Must be fixed before production or formally accepted.	Fix or accept with sign-off before production.
Low	Hygiene issue with limited exposure. Fix in normal course.	Track to closure.

Where a tool's severity differs from my rating, the finding says so and gives the reason. This happened in F-01 (kept High despite doubtful exploitability of two CVEs), F-03 and F-04 (lowered from High to Medium because the manifests are undocumented samples).

4. Governance

4.1 Project governance

Fineract is governed under the Apache Software Foundation model: a Project Management Committee (PMC) votes on releases, the code is Apache 2.0 licensed, and security reports go to a private channel handled by PMC members. The repository's SECURITY.md is a threat-model document that names the intended use cases (back-office core banking via REST, batch close-of-business processing, event publishing) and describes the private submission route. This is stronger than the usual one-paragraph policy.

4.2 Activity and concentration

In the twelve months to 8 September 2026 the repository had 133 distinct committers. The top contributor made 678 commits, the next four made 129, 113, 90 and 88. The project is clearly active (Scorecard Maintained 10/10), but a large share of the work depends on one person. For Bank A this is a continuity risk to note in the third-party register, not a finding against the software.

4.3 Release cadence and the gap between release and image

Release	Date	Gap from previous
1.12.0	15 Jul 2025	—
1.12.1	21 Jul 2025	6 days
1.13.0	11 Oct 2025	~3 months
1.14.0	19 Dec 2025	~2 months
1.15.0	10 Jul 2026	~7 months

Five releases in twelve months is a reasonable cadence. The problem is not the source releases but the container images: they are produced by CI from every commit on the development branch, and the development branch is 630 commits ahead of 1.15.0 as of 7 September 2026. A bank that pulls latest gets code that no PMC has voted on (F-02).

4.4 OpenSSF Scorecard

Scorecard result for commit 61c6bde794, generated 7 September 2026: 6.6/10. Full check list in Appendix B. Strong: Dangerous-Workflow, Maintained, Code-Review, Security-Policy, License (all 10), Pinned-Dependencies and Binary-Artifacts (9). Weak: Token-Permissions 0, SAST 0, Fuzzing 0, CII-Best-Practices 0, Branch-Protection 5. Signed-Releases and Packaging could not be evaluated because the project does not use GitHub Releases. The weak items produce findings F-06 and F-07.

4.5 Governance conclusion

The project's decision-making, review and disclosure processes meet what a bank would expect from an open-source supplier. The gaps are in build and release engineering: workflow permissions, branch protection, static analysis and, above all, the absence of release-tagged images. These are all fixable by the project and all avoidable by Bank A through building its own image.

5. Risk register

Likelihood and impact are rated 1 (low) to 3 (high). Inherent risk is the product before Bank A's controls; residual is the position after the conditions in section 8. The residual figures are targets: the conditions have not yet been implemented or tested, so verified residual risk has not been assessed and would require follow-up testing after go-live.

#	Asset	Threat	Inherent (L×I)	Existing controls in Fineract	Target residual	Finding
R1	#2 Authorisation	Attacker bypasses web-layer authentication and calls transaction APIs	3×3 = 9	Spring Security stack current; maker-checker enforced in command service	1×3 = 3	F-01
R2	#5 Supply chain	Bank deploys an image whose contents cannot be tied to a reviewed release	3×2 = 6	Source releases voted by PMC; SBOM producible	1×2 = 2	F-02
R3	#1 Ledger	Application-level bug escalates to full database write via over-privileged DB account	2×3 = 6	Credentials held in Kubernetes Secrets	1×3 = 3	F-03
R4	#4 Availability	Denial of service through Netty or HttpCore parsing flaws	2×2 = 4	Fixed versions available	1×2 = 2	F-01

#	Asset	Threat	Inherent (L×I)	Existing controls in Fineract	Target residual	Finding
R5	#5 Supply chain	Persistence or privilege abuse inside a compromised workload via writable filesystem and root context	2×2 = 4	None in sample manifests	1×2 = 2	F-04
R6	#5 Supply chain	Sample configuration reaches production unchanged	2×2 = 4	None (no README)	1×2 = 2	F-05
R7	#5 Supply chain	Compromise of a CI token or single account lands malicious code on the default branch	2×3 = 6	Mandatory code review; pinned build dependencies	1×3 = 3	F-06
R8	#1, #2	Injection or logic defect in Fineract code reaches production undetected	2×3 = 6	Code review; quality-checks workflow (no SAST)	1×3 = 3	F-07
R9	#3 Confidentiality	Database password read from process list inside a compromised container	1×2 = 2	Secret-backed environment variable	1×1 = 1	F-08
R10	#3 Confidentiality	Man-in-the-middle downgrade of database authentication (PostgreSQL driver)	1×2 = 2	Not applicable if MariaDB is used, as in the sample manifests	1×1 = 1	F-01

6. Compliance mapping

6.1 Regulatory versions and status at the date of issue

Regulatory texts change; a mapping is only meaningful against a stated version. The versions used in this report, and their status as at 8 September 2026, are:

Standard / regulation	Version used	Status at 8 September 2026
PRA SS2/21 Outsourcing and third party risk management	November 2024	In force (effective from 31 December 2024); the version this report maps against
PRA SS2/21, March 2026 update	Published 18 March 2026	Not yet in force; effective from 18 March 2027. Not applied in this report; tracked as a forward obligation in section 8.2
FCA SYSC 15A (operational resilience)	Current Handbook text	In force
EU DORA, Regulation (EU) 2022/2554	Applies from 17 January 2025	In force; applicability to the Irish branch is conditional (see Limitations)
BCBS Principles for the sound management of third-party risk	10 December 2025	Supervisory guidance, not directly binding; used as a benchmark only
ISO/IEC 27001:2022	2022	Voluntary control framework; common control language
NIST CSF 2.0	2.0 (2024)	Voluntary reference framework
BDDK information systems regulation (Türkiye)	Topic level only	Not verified against current text (see Limitations)

6.2 Mapping of findings

Bank A's primary regime is the UK one. DORA is mapped for the Irish branch on a conditional basis: whether the branch is an in-scope financial entity under DORA depends on its legal form and authorisation and would require legal validation in a real engagement (see Limitations). ISO/IEC 27001:2022 and NIST CSF 2.0 are given as the common control language. The Turkish column is included because Bank A's group has operations there; it is at topic level only (see Limitations).

Finding	UK (FCA/PRA)	EU (DORA, conditional)	ISO/IEC 27001:2022 Annex A	NIST CSF 2.0	Türkiye (BDDK regulation, topic)
F-01	PRA SS2/21 due diligence on ICT service providers; SYSC 15A impact tolerance	Art. 9 protection and prevention; Art. 28 third-party risk	A.8.8 technical vulnerabilities; A.5.21 supply chain	PR.PS-02 software patched	Vulnerability and patch management
F-02	PRA SS2/21 change and version control of outsourced systems	Art. 28 third-party risk; Art. 8 identification of ICT assets	A.8.32 change management; A.8.9 configuration management	PR.PS-01 configuration; GV.SC supply chain	Change management; asset inventory
F-03	PRA SS2/21 access controls at the provider	Art. 9 access management	A.8.2 privileged access rights; A.5.15 access control	PR.AA-05 access permissions	Privileged account management
F-04	SYSC 15A resilience of important business services	Art. 9 protection and prevention	A.8.9 configuration management; A.8.22 segregation of networks	PR.PS-01 configuration	System hardening
F-05	PRA SS2/21 documentation of the service	Art. 28 documentation of ICT services	A.5.37 documented operating procedures	GV.PO policy	Documentation of information systems
F-06	PRA SS2/21 supply-chain risk of the provider	Art. 28 third-party risk	A.5.21 supply chain; A.8.25 secure development	GV.SC-07 supplier risk	Software supply-chain controls
F-07	PRA SS2/21 secure development at the provider	Art. 9 secure development	A.8.28 secure coding; A.8.29 security testing	PR.PS-06 secure SDLC	Secure software development
F-08	PRA SS2/21 credential handling	Art. 9 access management	A.5.17 authentication information	PR.AA-01 identities and credentials	Credential protection

7. Audit findings

Each finding follows the same five lines: observation, evidence, impact on the assets in section 2.3, rating with reason, and recommendation split between Bank A and the project.

F-01 Deployed image ships Tomcat with three critical authentication vulnerabilities

Observation: The official container image apache/fineract:latest (built 7 September 2026) includes tomcat-embed-core 10.1.55. Trivy reports three CRITICAL vulnerabilities in this component: CVE-2026-65182 (security constraint bypass through improper access control), CVE-2026-65905 (authentication bypass via replay in the DIGEST authenticator) and CVE-2026-68525 (unauthorised resource access via FORM authentication bypass). All three are fixed in Tomcat 10.1.58, which was available before the image was built. The same scan reports eight HIGH findings: five in Netty 4.1.135 (denial of service, fixed in 4.1.136), two in HttpCore 5.4 (denial of service, fixed in

5.4.3) and one in the PostgreSQL driver 42.7.11 (SCRAM downgrade, fixed in 42.7.12). Fixed versions exist for all eleven. Of more than 260 JARs in the image only eleven carry a vulnerability; the Alpine 3.24.1 base has none and the Spring Security stack is current.

Evidence: fineract/evidence/trivy-image-crit-high.txt (full table); trivy-image-latest.txt, summary line "Total: 26 (CRITICAL: 3, HIGH: 8, MEDIUM: 13, LOW: 2)"; image digest sha256:e9389051, inspected 8 September 2026.

Impact: Assets #2 and #5. Tomcat is the web layer every Fineract API call passes through; an access-control bypass at this layer sits in front of the maker-checker control, not behind it. The Netty and HttpCore issues affect asset #4.

Rating: High. CVE-2026-65182 is a general access-control bypass with a public fix. The two DIGEST and FORM CVEs are unlikely to be reachable because Fineract authenticates through Spring Security rather than Tomcat's own authenticators, but this was not tested, and Bank A's patch policy does not recognise an "unused module" exception. The PostgreSQL driver CVE does not apply if Bank A uses MariaDB as the sample manifests do; it is retained for completeness.

Recommendation: Bank A to build its own image from the 1.15.0 source tag with Tomcat 10.1.58 and the other fixed versions, and to make a clean CRITICAL/HIGH scan a release gate before go-live. Project to be asked, through the Fineract dev list, to rebuild the published image with patched dependencies.

F-02 Official container images carry no release version tag

Observation: Docker Hub apache/fineract publishes images tagged only with commit hashes, develop and latest. The tags latest and develop point to the same commit (61c6bde794). Filtering the tag list for "1.15" and "1.14" returns no results. Source releases exist on the ASF site and as git tags; no container image corresponds to a released version. The development branch is 630 commits ahead of 1.15.0.

Evidence: screenshots/dockerhub-no-tag-1.15.png and dockerhub-no-tag-1.14.png; trivy-image-1.15.0.txt (FATAL: image apache/fineract:1.15.0 not found); git describe --tags on develop, 8 September 2026.

Impact: Asset #5. The mutable latest image can be uniquely identified by its digest, but the published artefact cannot be demonstrated to correspond to a formally voted Fineract release without additional provenance mapping. Consuming latest therefore weakens release approval, build reproducibility and change-governance assurance, and leaves Bank A unable to show a change-management trail for the image.

Rating: High. PRA SS2/21 and ISO 27001 A.8.32 require controlled, identifiable change; an image that moves daily fails that test regardless of its content.

Recommendation: Bank A to build and sign its own image from the 1.15.0 source tag and pin it by digest. Project to be asked to publish release-tagged images alongside latest.

F-03 Database bootstrap grants the root account full rights from any host

Observation: The init script in kubernetes/fineractmysql-configmap.yml runs GRANT ALL ON *.* TO 'root'@'%'. The application's own database username is read from a Kubernetes Secret, so I could not confirm from the repository whether Fineract connects as root or as a limited user.

Evidence: fineractmysql-configmap.yml, data.init.sql, last line; fineract-server-deployment.yml lines 94 to 103.

Impact: Assets #1 and #2. If the root account is reachable from the application network, any code-execution bug in the application becomes full read and write access to the ledger.

Rating: Medium. The manifests' intended use is not documented (F-05) and Bank A would write its own. I would raise this to High if these files were used as-is in production.

Recommendation: Bank A to create a dedicated application account with rights limited to the tenant schemas and to restrict root to localhost. Project to be asked to replace the wildcard grant in the sample script.

F-04 Sample Kubernetes deployments run with default security context

Observation: Trivy reports 73 misconfigurations across the three deployment manifests (30, 30 and 13), thirteen rated HIGH: containers do not set readOnlyRootFilesystem (KSV-0014) and use the default security context, which

permits root inside the container (KSV-0118). No CRITICAL.

Evidence: trivy-1.15.0.txt, misconfiguration section, 8 September 2026.

Impact: Assets #5 and #4. These settings increase post-compromise capability and persistence within the workload: a compromised container could modify its own filesystem and run as root inside it. Escape to the underlying node would require an additional runtime or kernel vulnerability or misconfiguration; the settings do not create that path on their own.

Rating: Medium. Trivy rates these HIGH; I have lowered them for the same reason as F-03, but they must be fixed before any use.

Recommendation: Bank A to apply a hardened pod security baseline (non-root user, read-only root filesystem, dropped capabilities) in its own manifests.

F-05 Deployment manifests have no stated purpose

Observation: The kubernetes/ directory contains five manifests and two shell scripts and no README. Nothing states whether the files are for development, demonstration or production.

Evidence: ls /tmp/fineract/kubernetes, 8 September 2026; kubernetes/README.md does not exist.

Impact: Asset #5. Undocumented sample configuration is the usual route by which a demo setting reaches production.

Rating: Low on its own. It is the reason F-03 and F-04 are rated Medium rather than High.

Recommendation: Project to be asked to add a README marking the manifests as non-production. Bank A to treat them as reference only.

F-06 CI workflows do not follow least privilege; branch protection is partial

Observation: OpenSSF Scorecard (commit 61c6bde794, 7 September 2026) scores Token-Permissions 0/10 and Branch-Protection 5/10. Code-Review and Maintained score 10/10. The repository runs ten build workflows including a separate quality-checks workflow.

Evidence: screenshots/scorecard.png; overall score 6.6/10; ls .github/workflows.

Impact: Asset #5. Over-permissioned workflow tokens are a common entry point for supply-chain attacks on open-source projects; partial branch protection means a single account compromise could land code on the default branch.

Rating: Medium. Mitigated by mandatory code review, which Scorecard confirms.

Recommendation: Bank A to build from a pinned source tag it has reviewed, not from develop. Project to be asked to set read-only permissions as the workflow default and to require status checks on develop.

F-07 No static analysis or fuzzing in the project pipeline

Observation: Scorecard scores SAST 0/10 and Fuzzing 0/10. Dependency hygiene is otherwise good, as noted in F-01.

Evidence: screenshots/scorecard.png; trivy-image-latest.txt summary table.

Impact: Assets #1 and #2. The pipeline lacks a dedicated static-analysis control, which reduces assurance that source-level security defects, including injection-type flaws, are systematically detected before merge or release. Code review and tests provide some coverage but are not a substitute for automated static analysis.

Rating: Medium.

Recommendation: Bank A to run its own SAST (for example Semgrep with the OWASP ruleset) on the pinned source tag before go-live and to treat results as conditions of approval.

F-08 Database password passed on the command line in health probes

Observation: The MariaDB readiness and liveness probes run `mariadb -uroot -p${MARIADB_ROOT_PASSWORD}`. The password is sourced correctly from a Secret, but a command-line argument is visible in the process list inside the container.

Evidence: `fineractmysql-deployment.yml` lines 108 and 116.

Impact: Assets #3 and #2, limited: exposure requires access inside the container.

Rating: Low.

Recommendation: Use a `.my.cnf` file or the `MYSQL_PWD` environment variable in probes. Bank A to apply the same rule in its own manifests.

7.9 Controls operating as expected

An assessment that lists only failures is not balanced. The following controls were tested or observed and found in place:

- Database credentials are held in Kubernetes Secrets and referenced with `secretKeyRef`; no plaintext password was found in any manifest.
- A published security policy exists (`SECURITY.md`) with a private reporting route and a threat model naming the intended use cases.
- Human code review is required before merge (Scorecard Code-Review 10/10).
- The project is actively maintained: 133 committers and five releases in twelve months.
- Build dependencies are pinned (Scorecard 9/10) and no binary artefacts are committed to source (9/10).
- The container base image (Alpine 3.24.1) has no known vulnerabilities, and the Spring Boot and Spring Security stack is on current versions.
- Maker-checker (four-eyes) approval is implemented in the command-processing service (`fineract-core`, `commands/service`).

8. Recommendations and conditions of approval

8.1 Conditions before go-live (Bank A)

#	Condition	Owner	Effort	Closes
C1	Build, sign and digest-pin an image from source tag 1.15.0 with Tomcat 10.1.58, Netty 4.1.136, HttpCore 5.4.3 and PostgreSQL driver 42.7.12; require a zero CRITICAL/HIGH scan as a release gate	Platform engineering	M	F-01, F-02
C2	Write Bank A's own manifests: dedicated least-privilege DB account, root restricted to localhost, non-root containers, read-only root filesystem, dropped capabilities, probes without command-line passwords	Platform engineering	M	F-03, F-04, F-05, F-08
C3	Run SAST on the pinned source tag; close or formally accept every High finding	Application security	S	F-07

8.2 Ongoing obligations (Bank A)

- Re-scan and rebuild on every Fineract release and at least quarterly; subscribe to the ASF security announcements list.
- Record Fineract in the third-party and ICT asset registers as a material ICT service (PRA SS2/21; DORA Art. 28 register of information for the Irish branch, subject to the applicability note in section 6).
- Note the contributor-concentration risk (section 4.2) in the register and review it annually.

- Formally designate (or document the decision not to designate) the micro-loan service as an important business service under SYSC 15A, set an impact tolerance for it, and test that the Fineract deployment can be restored within that tolerance.
- After the conditions are implemented, test them and update the risk register from target to verified residual risk.
- Track the March 2026 update to SS2/21, effective 18 March 2027, and re-check the third-party register and notification arrangements for Fineract against it before that date; use the BCBS Principles for the sound management of third-party risk (December 2025) as a benchmark when reviewing the TPRM framework.

8.3 Requests to the project

- Publish release-tagged, signed container images alongside latest (F-02).
- Rebuild the published image with patched dependencies (F-01).
- Add a README to kubernetes/ marking the manifests as non-production, and remove the wildcard root grant (F-03, F-05).
- Set read-only default permissions on GitHub Actions workflows and enable full branch protection on develop (F-06).
- Add SAST to the quality-checks workflow (F-07).

These requests will be raised on the Fineract dev mailing list after publication of this report. No previously unknown vulnerability was found; nothing in this report requires private disclosure.

Appendix A. Evidence index

File	What it is	Used in
evidence/trivy-1.15.0.txt	Trivy source scan of tag 1.15.0 (vuln, secret, misconfig)	F-04, Limitations
evidence/trivy.txt	Trivy source scan of develop at 61c6bde794	Reference
evidence/sbom-1.15.0.json	CycloneDX SBOM of the source tree (132 packages; incomplete, see Limitations)	Limitations
evidence/trivy-image-latest.txt	Trivy scan of apache/fineract:latest, all severities	F-01, 7.9
evidence/trivy-image-crit-high.txt	Same scan filtered to CRITICAL and HIGH	F-01
evidence/trivy-image-1.15.0.txt	Failed pull of apache/fineract:1.15.0 (tag does not exist)	F-02
screenshots/dockerhub-no-tag-1.15.png, -1.14.png	Docker Hub tag filter showing no results	F-02
screenshots/scorecard.png	OpenSSF Scorecard report, 6.6/10	Section 4, F-06, F-07

Appendix B. OpenSSF Scorecard checks

Commit 61c6bde794, generated 7 September 2026, Scorecard v5.5.0, overall 6.6/10.

Check	Score	Risk weight
Dangerous-Workflow	10	Critical
Token-Permissions	0	High
Branch-Protection	5	High
Binary-Artifacts	9	High

Check	Score	Risk weight
Maintained	10	High
Code-Review	10	High
Signed-Releases	not evaluated	High
Fuzzing	0	Medium
SAST	0	Medium
Pinned-Dependencies	9	Medium
Security-Policy	10	Medium
Packaging	not evaluated	Medium
CI-Best-Practices	0	Low
License	10	Low

Appendix C. CRITICAL and HIGH vulnerabilities in apache/fineract:latest

Component	Installed	CVE	Severity	Fixed in	Summary
tomcat-embed-core	10.1.55	CVE-2026-65182	CRITICAL	10.1.58	Security constraint bypass, improper access control
tomcat-embed-core	10.1.55	CVE-2026-65905	CRITICAL	10.1.58	Authentication bypass, DIGEST replay
tomcat-embed-core	10.1.55	CVE-2026-68525	CRITICAL	10.1.58	Unauthorised access, FORM authentication bypass
netty-codec	4.1.135	CVE-2026-59901	HIGH	4.1.136	Infinite loop in bzip2 decompression
netty-codec-http	4.1.135	CVE-2026-55831	HIGH	4.1.136	DoS via SPDY SETTINGS frame
netty-codec-http	4.1.135	CVE-2026-55833	HIGH	4.1.136	DoS via SPDY header decompression
netty-codec-http	4.1.135	CVE-2026-56745	HIGH	4.1.136	DoS via memory exhaustion in SPDY codec
netty-codec-http2	4.1.135	CVE-2026-56819	HIGH	4.1.136	DoS via HTTP/2 DATA frame memory leak
httpcore5	5.4	CVE-2026-54399	HIGH	5.4.3	DoS via excessive HTTP headers
httpcore5-h2	5.4	CVE-2026-54428	HIGH	5.4.3	DoS via oversized HPACK header
postgresql	42.7.11	CVE-2026-54291	HIGH	42.7.12	MITM protection bypass, SCRAM downgrade